

PHISHGUARD

DevSecOps-Based Phishing Email Detection System

60
automated
tests passed

0-100
explainable risk
score

RED

YELLOW

GREEN

Detect · Analyse · Protect

Tashi Namgay (CIHE241207) · Giovanni · Masaba · Aditi
Crown Institute of Higher Education | ICT932 Cybersecurity Testing and Assurance | S1 2026

THE PROBLEM

- Phishing emails exploit trust, urgency and hidden malicious links.
- Simple filters struggle with changing wording, attachment tricks and sender mismatch.
- Users need risk explanation, not only a safe/phishing label.

OBJECTIVES

- Build a browser-based phishing email detector.
- Analyse URLs, keywords, headers and attachments.
- Show RED / YELLOW / GREEN risk level with reasons.
- Secure access with bcrypt, RBAC, CSRF protection and optional 2FA.
- Provide PDF/CSV report export and quarantine review workflow.

SECURITY CONTROLS

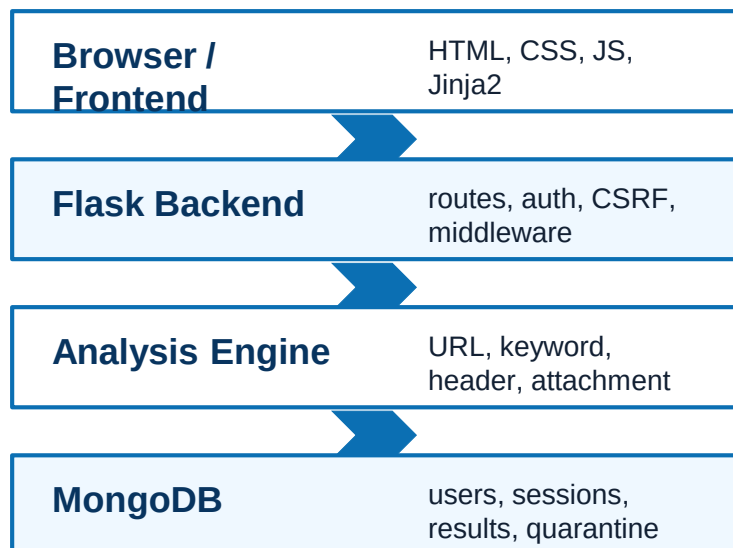
AUTH	bcrypt + Flask-Login sessions
RBAC	admin and analyst route protection
2FA	PyOTP TOTP optional per user
CSRF	WTForms tokens on browser forms
INPUT	.txt, .eml and .docx upload controls
AUDIT	login attempts saved for review

DEVELOPMENT EVIDENCE

[illegible]

PyTest, Bandit, pip-audit and OWASP ZAP were used to make security evidence part of development, not an afterthought.

SYSTEM ARCHITECTURE



EMAIL ANALYSIS PIPELINE

URL

IP links, shorteners,
phishing-word
domains

Keyword
urgency, finance
and password
request language

Header

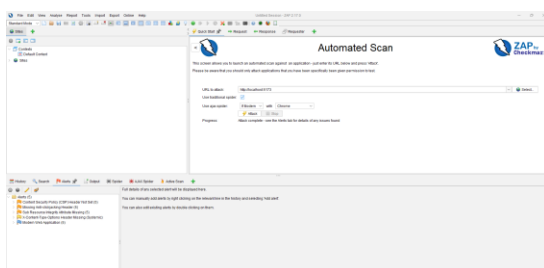
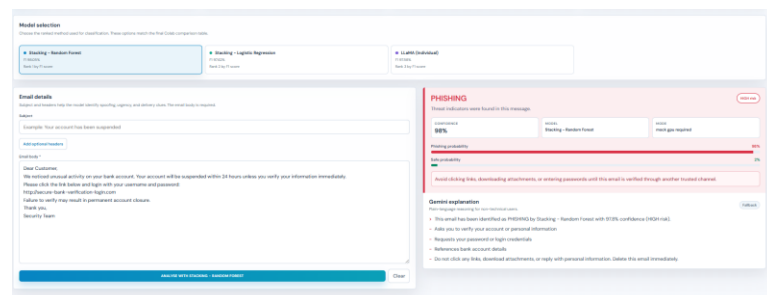
reply-to mismatch
and sender
anomalies

Attach

dangerous or
double-extension
files

The four modules combine into a scored, explainable risk output.

APPLICATION INTERFACE



DEVSECOPS LIFECYCLE

1	2	3	4	5
Plan	Build	Secure	Test	Evaluate

Threat modelling, secure coding and automated testing produced repeatable project evidence.

TESTING & VALIDATION

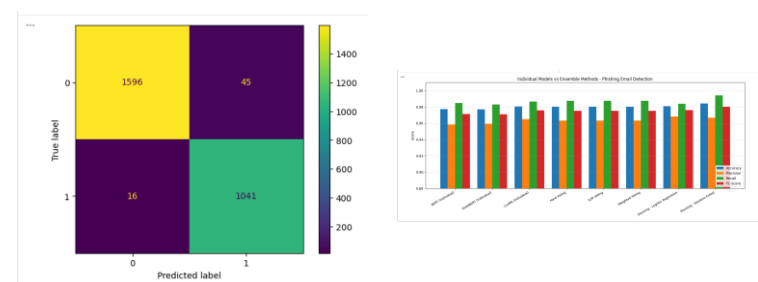
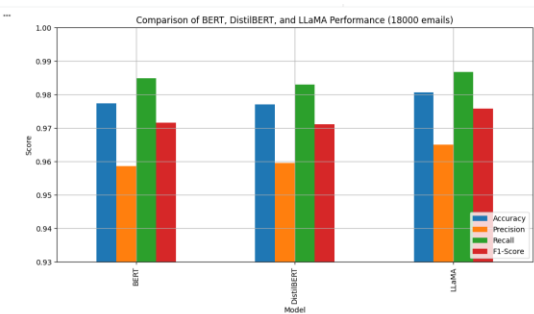
5 testing layers

PDF +
CSV
report
export

RBA C access control

- Unit tests: parser, URL, attachment, scoring and keyword matching.
- Auth tests: login, protected routes, approval flow and sessions.
- Security regression: CSRF, 2FA, export controls and upload extraction.

ML / MODEL EVIDENCE



Colab evidence compares BERT, DistilBERT, LLaMA and ensemble approaches behind the detection prototype.

RESULTS & IMPROVEMENTS

- Manual input and .txt/.eml/.docx upload are working.
- Risk score returns a colour level and plain-language reasons.
- PDF and CSV report downloads are functional.
- CSV export now checks for existing records before creating files.
- Analysis results display on the same Analyse Email page.
- UI labels and colour system were redesigned for clarity.

LIMITATIONS & FUTURE WORK

- Rule-based detection can miss new phishing styles.
- ML classifier depends on dataset quality.
- Production HTTPS, Docker and CI/CD scanning remain future work.
- Add URL reputation, SPF/DKIM/DMARC checks and monitoring.

CONCLUSION

PhishGuard demonstrates a complete academic cybersecurity prototype: secure access control, explainable phishing risk analysis, analyst/admin workflows, and repeatable DevSecOps testing evidence.
Detect threats. Explain risk. Protect users.

Technology Stack

Python Flask · MongoDB · Jinja2 ·
PyOTP
PyTest · Bandit · pip-audit · OWASP
ZAP